

IN THIS CHAPTER

- » Assessing the risk for security
- » Looking at two pillars of cybersecurity
- » Identifying the most important protection and recovery measures
- » Examining standardized cybersecurity frameworks
- » Looking more closely at the NIST Cybersecurity Framework

Chapter 4

Cybersecurity

As an IT professional, cybersecurity is the thing most likely to keep you awake at night. Consider the following scenarios:

- » Your phone starts ringing like crazy at three o'clock one afternoon because no one anywhere on the network can access any of their files. You soon discover that your network has been infiltrated by *ransomware*, nefarious software that has encrypted every byte of data on your network, rendering it useless to your users until you pay a ransom to recover the data.
- » Your company becomes a headline on CNN because a security breach has resulted in the theft of your customers' credit card information.
- » On their last day of work, a disgruntled employee copies your company contact list and other vital intellectual property to a flash drive and walks away with it along with their red Swingline stapler. A few months later, your company loses its biggest contract to the company where this jerk now works.

There is no way you can absolutely prevent such scenarios from ever happening, but with proper security, you can greatly reduce their likelihood. This chapter presents a brief overview of some of the basic principles of securing your network.

Cybersecurity goes hand in hand with networking. In fact, the moment you think of building a network, you should lay the groundwork for how you'll keep it secure. You should consider the security aspects of a network from the very start and throughout the design and implementation of your network. Security will touch every aspect of your network environment — not just network equipment such as firewalls and switches, but also servers, end-user computers, user accounts, data storage, and so on.

But We're a Small Business — Do We Need Security?

It's tempting to think that cybersecurity is important only to large enterprises. In a small business, everyone knows and trusts everyone else. Folks don't lock up their desks when they take a coffee break, and although everyone knows where the petty cashbox is, money never disappears.

Cybersecurity isn't necessary in an idyllic setting like this one — or is it? You bet it is. Here's why any network should be set up with built-in concern for security:

- » **Mitts off:** Even in the friendliest office environment, some information is and should be confidential. If this information is stored on the network, you want to store it in a directory that's available only to authorized users.
- » **Hmm:** Not all security breaches are malicious. A network user may be routinely scanning files and come across a filename that isn't familiar. The user may then call up the file, only to discover that it contains confidential personnel information, juicy office gossip, or your résumé. Curiosity, rather than malice, is often the source of security breaches.
- » **Trust:** Sure, everyone at the office is trustworthy *now*. But what if someone becomes disgruntled, a screw pops loose, and they decide to trash the network files before jumping out the window? Or what if someone decides to print a few \$1,000 checks before packing off to Tahiti?
- » **Temptation:** Sometimes the mere opportunity for fraud or theft can be too much for some people to resist. Give people free access to the payroll files, and they may decide to vote themselves a raise when no one is looking.

If you think that your network contains no data worth stealing, think again. For example, your personnel records probably contain more than enough information for an identity thief: names, addresses, phone numbers, Social Security numbers, and so on. Also, your customer files may contain your customers' credit card numbers.

- » **Malice:** Hackers who break into your network may not be interested in stealing your data. Instead, they may be looking to plant a *Trojan horse* program on your server, which enables them to use your server for their own purposes. For example, someone may use your server to send thousands of unsolicited spam email messages. The spam won't be traced back to the hackers; it will be traced back to you.
- » **Whoops:** Bear in mind that not everyone on the network knows enough about how your operating system and the network work to be trusted with full access to your network's data and systems. One careless mouse click can wipe out an entire directory of network files. One of the best reasons for activating your network's security features is to protect the network from mistakes made by users who don't know what they're doing.

The Two Pillars of Cybersecurity

There are two basic elements that you must consider as part of your cybersecurity plan:

- » **Prevention:** The first pillar of cybersecurity is the tools and technology that you can deploy to prevent bad actors from penetrating your network and stealing or damaging your data. This pillar includes firewalls that block unwelcome access, antivirus programs that detect malicious software, patch management tools that keep your software up-to-date, and anti-spam programs that keep suspicious email from reaching your users' inboxes.
- » **Recovery:** The second pillar of cybersecurity is necessary because the first pillar isn't always successful. Successful cyberattacks are inevitable, so you need to have technology and plans in place to quickly recover from them when they hit. This pillar includes such things as creating backup copies of all your data and having recovery plans in place to quickly get your organization back up and running.

I cover both of these pillars in greater detail in the following sections.

Prevention

A comprehensive cybersecurity plan is filled with prevention measures.

First and foremost, your prevention measures should start with a complete understanding of your IT environment, the threats it's exposed to, and the vulnerabilities

it presents to would-be attackers. The foundation of this knowledge is an *asset management system* that lets you keep track of absolutely everything that's connected to your network. This inventory includes at least the following:

- » **All the hardware connected to your network:** That includes all the desktop computers, mobile devices, servers, switches, Wi-Fi access points, routers, printers, and every other piece of hardware connected to your network.
- » **All the software connected to your network:** That includes operating systems, web browsers, Microsoft Office applications, and any other programs your organization uses. It also includes cloud service providers such as Microsoft 365, online meeting platforms, cloud storage providers, and so on. Finally, it includes the software that runs on devices such as routers, switches, printers, and other similar devices.
- » **All the people connected to your network, typically represented by Active Directory accounts:** You need to understand who they are, what their jobs are, what permissions they require, and what devices they use.

With the information gleaned from this asset management, you can deploy specific preventive measures to protect each asset. The following list is not complete, but it's a good starting point:

- » **Firewalls:** Your internet connection must be protected by a firewall device that's configured to keep dangerous traffic out of your network. (For more information, see Book 10, Chapter 2.)
- » **Wi-Fi security:** All wireless access to your network must be encrypted and protected by password access. (For more information, see Book 4, Chapter 2.)
- » **Antivirus software:** Every computer on your network must be protected by active antivirus software. That includes *every* computer — workstations, laptops, tablets, and servers. All it takes is one unprotected computer to expose your entire environment to attack. (For more information, see Book 10, Chapter 2.)
- » **Anti-spam software:** Most cyberattacks come in through email. Make sure all email is protected by anti-spam software that can block email that contains malicious code or suspicious links. (For more information, see Book 10, Chapter 3.)
- » **Strong passwords:** All accounts that have access to your systems should be secured by strong passwords. (For more information, see Book 10, Chapter 1.)
- » **Multifactor authentication:** The most critical access, such as for those with administrative control, should be controlled by multifactor authentication, which requires additional verification beyond a username and password. (For more information, see Book 10, Chapter 1.)

» **Data protection:** All shared data on your network should be protected with roll-based security so that only those users who have a demonstrated need for the data are allowed access. This is done by controlling access permissions on files and folders, as well as share permissions. (For more information, see Book 6, Chapter 5.)

» **Encryption:** *Encryption* refers to the process of encoding data so that it can be read only by those who possess the secret encryption key. Encryption is one of the most important aspects of data security and should be employed whenever possible.

One common way to use encryption is on wireless networks, where all data should be encrypted. This type of encryption is called *data-in-flight encryption* because it encrypts data while it's in transit from one computer or device to another. It's also common to encrypt data that resides on disk drives — this type of encryption is called *data-at-rest encryption* and is especially important if someone physically steals your disk drives (or the computers that contain them).

» **User life-cycle management:** All user accounts should be subject to a documented life-cycle management policy that ensures that when a user leaves the organization, that user's access is terminated.

» **Auditing:** All aspects of your security environment should be regularly audited to ensure everything is operating as expected and is appropriate for the current environment. This includes regularly reviewing your user accounts and file permissions; reviewing firewall, antivirus, and anti-spam software to make sure it's functioning; and reviewing event logs.

» **User training:** The weakest points in any network are its users. Make sure to regularly offer security training for your users. (For more information, see Book 10, Chapter 1.)

» **Physical security:** This aspect of cybersecurity is often overlooked. Any hacker worth their salt can quickly defeat all but the most paranoid security measures if they can gain physical access to a computer on your network. Make sure the server room is locked at all times. Make sure your users lock their computers when they step away from their desks.

Recovery

No matter how good your prevention measures are, cybersecurity events are bound to happen. A user will exercise bad judgement and click a link in a phishing email, an important security patch will be neglected and an intruder will exploit the resulting weakness, or someone's password will be compromised. It's bound to happen, so your cybersecurity plan must include recovery measures in addition to prevention measures.

A recovery plan should also protect you against threats that aren't necessarily malicious. For example, what if a hardware failure takes out a key file server and you lose all its data? Or what if there's a fire in the server room? Disasters like these are unlikely but not impossible. For more information about disaster recovery planning, check out Book 10, Chapter 4.



TIP

The most important aspect of recovery is to plan for it in advance. Don't wait until after a cyberattack has succeeded to start wondering how you can recover. Instead, assume that a cyberattack *will* eventually happen, and plan in advance how you'll recover.

The basis of any recovery plan is a good backup plan. In fact, planning for backup is an integral part of planning any network. I've devoted Book 3, Chapter 6 to this topic, so I won't go into every detail here. But for now, know that backups must be:

- » **Comprehensive:** Identify every critical server and data store in your organization, and make sure it's backed up regularly.
- » **Up-to-date:** When you're forced to recover from a backup, you'll be rolling your business back to the date the backup was made. If that was three weeks ago, you'll lose three weeks' worth of work.
- » **Redundant:** Keep multiple copies of your backups, each representing a different recovery point. At the minimum, keep at least three generations of backups. That way, if the most recent set of backups doesn't work, you can revert to the set before that and, if necessary, the set before that. A key factor to consider is that if your files have been corrupted by a cyberattack and you don't discover the attack right away, your backups may contain copies of the corrupted data. You want to make sure that you have a good backup that was made *before* the attack occurred.
- » **Kept off-site:** If a fire burns down your server room and your backups are kept on a shelf next to the servers, you'll lose the backups, too. At that point, you won't be able to restore anything.
- » **Offline:** It's not enough to keep backups off-site; they must also be offline. Backing up to the cloud is popular, but keep in mind that a hacker skilled enough to break into your network and delete files on your servers may also be skilled enough to delete your cloud backups as well.
- » **Automated:** Don't rely on remembering to run a backup every Friday at the end of the day. You'll forget. Make sure your backup processes are automated.
- » **Monitored:** Don't assume backups worked this week just because they worked last week. Monitor your backups regularly to ensure they're working as designed.

- » **Tested:** Don't wait until the pressure of a recovery to see if your backups actually work. Regularly test them by restoring individual files and entire servers.

Here are a few other elements your recovery plan should include:

- » **Spare computers:** If a cyberattack compromises one of your desktop computers, make sure you have a spare or two that you can quickly configure to quickly get the user back to work.
- » **Emergency disk capacity:** Restore operations often require that you have plenty of spare disk capacity available so that you can move data around. Inexpensive network-attached storage (NAS; see Book 3, Chapter 5) may fill the bill, but keep in mind that this type of storage is very slow. If you rely on it, you may find that it takes several days to recover multiple terabytes of data.
- » **Communications:** In the midst of a recovery from a cyberattack, communicating with your users is critical. They'll need to know what's going on, how long you expect the recovery to take, and so on. Unfortunately, this communication may be difficult if the normal channels of communication — such as email — have been disrupted by the attack. So, you should plan in advance for alternative methods of communicating with users, such as cloud-based communication platforms like Microsoft Teams or Slack.

Cybersecurity Frameworks

You may think that all you need to do to secure your network is install a firewall, run antivirus software on all your computers, and back up all your data. Those are important first steps, but cybersecurity is much bigger than a checklist of things to do.

In fact, cybersecurity should be baked into your IT systems from the ground up. Every aspect of your system designs should take cybersecurity into account, not as an afterthought but from the very beginning. That includes your servers, storage platforms, desktop computers, network infrastructure (including switches, routers, firewalls, cables, and wireless networks), mobile devices, operating systems, software, and anything else that's part of your IT environment.

It's a daunting task, but fortunately you're not alone in figuring out how to make cybersecurity a top priority in your IT organization. Plenty of resources are available to you — including standardized frameworks that can help you plan and implement your security environment.

You have plenty of cybersecurity frameworks to choose from. Although most of these frameworks are similar, there are subtle differences. Here are five of the most popular cybersecurity frameworks you may want to investigate:

- » **NIST:** The NIST Cybersecurity Framework is probably the most commonly used framework in the United States. It's governed by the National Institute of Standards and Technology (NIST). (For more information about this popular framework, refer to the next section, "The NIST Cybersecurity Framework.")
- » **ISO/IEC 27001:** This is the most popular international cybersecurity framework. For more information, go to www.iso.org/standard/27001.
- » **ISA/IEC 62443:** The International Society of Automation (ISA) sponsors a series of standards known as ISA/IEC 62443, which comprise a flexible framework for managing security. For more information, head to www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards.
- » **CIS Critical Security Controls:** The Center for Internet Security (CIS) provides a list of 18 cybersecurity controls that can be used as a framework for organizing your cybersecurity measures. For more information, go to www.cisecurity.org/controls/cis-controls-list.
- » **Control Objectives for Information and Related Technologies (COBIT):** Sponsored by the Information Systems Audit and Control Association (ISACA), COBIT is one of the more popular cybersecurity frameworks. For more information, head to www.isaca.org/resources/cobit.

The NIST Cybersecurity Framework

In 2014, NIST issued the first version of its cybersecurity framework, officially known as the Framework for Improving Critical Infrastructure Cybersecurity but commonly referred to as the NIST Cybersecurity Framework (and often when speaking in the context of cybersecurity simply NIST). I refer to it simply as "the framework" throughout the rest of this chapter.

The framework was originally intended to apply to critical infrastructure such as the power grid, transportation systems, dams, government agencies, and so on. But it quickly became popular in the private sector as well and is now considered one of the best overall tools for planning cybersecurity for large and small organizations, public and private.

The framework is useful for any organization large enough to have a dedicated IT staff, even if that staff consists of just one person. No organization can or should implement every detail that is spelled out in the framework. Instead, the framework invites you to develop a solid understanding of the cybersecurity risks your organization faces and to implement a risk management strategy based on informed decisions about which security practices make sense for your organization.

In 2018, NIST issued a new version of the framework, known as version 1.1. This version added a section on self-assessment and greatly expanded its coverage of the cybersecurity risk associated with business supply chains.

The current version of the framework, known as version 2.0, was released in February 2024. It added additional information about how an organization can provide oversight for cybersecurity by formally adopting a governance function.

You can find the complete documentation for the NIST Cybersecurity Framework at www.nist.gov/cyberframework strongly suggest you download the framework document, print it out, and read it. It's only about 32 pages.

The framework consists of three basic components:

» **Cybersecurity Framework Core:** This section identifies six basic functions of cybersecurity:

- **Govern:** This function provides a formalized method to ensure that the other five functions are properly planned, implemented, and monitored.
- **Identify:** This function helps you determine, in detail, exactly what parts of your organization are vulnerable to cyberattack.
- **Protect:** This function enables you to take specific steps to protect those parts of your organization that you've identified as being vulnerable.
- **Detect:** This function involves monitoring your systems and environment so that you know as soon as possible when a cyberattack occurs.
- **Respond:** This function helps you plan in advance how you'll respond when a cybersecurity incident occurs.
- **Recover:** This function prompts you to develop plans and procedures to restore any parts of your environment that were damaged by a cyberattack. For example, if data was lost, you may need to restore the lost data from backup copies.

Within each of these six basic functions, best practices, guidelines, and standards are presented focusing on specific cybersecurity outcomes, such as “Remote access is managed” or “Removable media is protected and its use restricted according to policy.” I offer more detail on the Cybersecurity Framework Core later in this section.

- » **Cybersecurity Framework Organizational Profiles:** This section discusses the use of profiles to indicate which specific outcomes in the Cybersecurity Framework Core are implemented. You can create a *current profile*, which documents the current cybersecurity practices at your organization, and then create a *target profile* to represent where you'd like to be. Then you can devise a plan to move from the current profile to the target profile.
- » **Cybersecurity Framework Tiers:** This section describes four distinct tiers that represent an increasing level of sophistication in cybersecurity practices. As an organization invests more in cybersecurity, it moves up through the tier levels.

Each of the six functions of the Cybersecurity Framework Core (listed earlier) is divided into several categories, which are in turn divided into subcategories. A simple numbering scheme is used to track the functions, categories, and subcategories. For example, the Identify function is designated by the identifier *ID*. Its first category is Asset Management, which is designated by *ID.AM*. The first subcategory under Asset Management is “Inventories of hardware managed by the organization are maintained,” and it's designated *ID.AM-01*. Table 4-1 lists the six functions along with each function's categories and the identifier for each.

TABLE 4-1 **The Functions and Categories of the NIST Framework Core**

Function	Category	Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversite	GV.OV
	Cybersecurity Supply Chain Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM

Function	Category	Identifier
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

In all, there are 22 categories across the six functions. Each of these categories is broken down into from 2 to 10 subcategories, for a total of 106 subcategories altogether.

The framework doesn't prescribe specific solutions for each of the 106 subcategories; it merely states the outcome to be achieved by each subcategory and invites you to design a solution that produces the desired outcome. For example, the first subcategory of Asset Management (ID.AM-01) is as follows:

Inventories of hardware managed by the organization are maintained

You can accomplish this goal in many ways. If your organization is small, you may just keep track of all your computer and network devices in a simple Microsoft Excel spreadsheet. If your organization is larger, you may use software that automatically scans your network to create a catalog of all attached devices, and you may want to use inventory tags with barcodes so you can track hardware assets. But one way or another, keeping an inventory of all your physical devices and systems is a vital element of cybersecurity.



REMEMBER

Although the framework doesn't prescribe specific solutions, it does offer a set of links to other cybersecurity frameworks, which it calls *Informative References* (www.nist.gov/informative-references). You can cross-reference these Information References to gain additional insight into each of the subcategories.

